TRUETONE · WHAT BREAKING THE RULES COSTS

Risk & Penalty Summary

The financial and existential exposure for each compliance rule — ranked by danger to a small Illinois startup.

Most of these penalties are **per person** or **per violation**, so they scale brutally with users. The danger isn't only the headline fine — it's that several of these laws let **private individuals or class-action lawyers sue you directly**, forcing a settlement before you can mount a defense. Figures below are statutory maximums and real settlements; actual exposure depends on the facts.

Rule broken	Who can come after you	Penalty	Real-world example
Illinois BIPA biometric consent / retention	**Individuals (private suits / class actions)** — no proof of harm needed	**$1,000 / person** (negligent); **$5,000 / person** (reckless) + attorneys' fees	Facebook **$650M**; Google $100M; TikTok $92M
Washington MHMDA 'consumer health data' consent	**Individuals** (private right of action) + WA Attorney General	Consumer-Protection-Act damages; up to **$7,500/violation** (AG); private treble damages + fees	New law; private suits emerging — treat as a 2nd BIPA
Texas CUBI biometric capture	Texas Attorney General only	Up to **$25,000 / violation**	Meta **$1.4 BILLION** (largest biometric settlement)
FTC Health Breach Rule leaking health data / no breach notice	FTC / DOJ	Up to **~$53,000 / violation, per day** + permanent bans	GoodRx **$1.5M**; BetterHelp $7.8M; Premom $100K
FTC Act §5 false/AI claims, broken privacy promise	FTC	Consumer refunds, disgorgement, **20-year** consent decree, injunctions	BetterHelp $7.8M refunds; Match Group action
COPPA collecting minors' face data	FTC / DOJ + state AGs	Up to **~$53,000 / violation**	Epic/Fortnite **$275M**; Genshin $20M
FDA — unapproved medical device diagnosing / treating disease	FDA	Warning letter → forced market removal, seizure, injunction, civil penalties; possible criminal	Existential: product pulled, not just fined
State privacy laws CCPA/CPRA, VA, CO, CT, TX…	State AGs / California CPPA	Civil penalties ~**$2,500–$7,500 / violation** + consumer suits (CA)	Disney $2.75M (2/2026); Healthline $1.55M
GDPR (only if you serve EU users)	EU data-protection regulators	Up to **€20M or 4% of global annual revenue**, whichever is higher	Avoid in v0 by staying US-only
Apple App Store guideline violations	Apple (private platform)	No fine — but app **rejection / removal / developer-account termination**	No app = no business

■ can end the company / hits hardest ■ serious ■ deferrable in v0

Why this is worse than the headline numbers suggest

These laws don't usually start with a polite warning. For a small company the real damage is the **mechanism**, not just the fine:

- **Private lawsuits + class actions (BIPA, Washington).** Plaintiffs' firms watch this space full-time and file before you can react. You typically settle because fighting costs more.
- **It scales per user.** Improper biometric consent for **10,000 Illinois users** = **$10M** at the negligent rate, **$50M** at the reckless rate — before legal fees.
- **Permanent bans + 20-year oversight.** FTC orders routinely ban you from the data practice entirely and impose two decades of third-party privacy audits.
- **The app can simply vanish.** An Apple removal or an FDA 'stop selling' letter ends revenue overnight, regardless of any fine.
- **Legal fees dwarf the penalty.** Defending one class action can cost more than many of the settlements above.

MAKE IT CONCRETE — THE BIPA MATH

Skip the consent screen, launch in Illinois, sign up 25,000 users. If a court finds the violation merely **negligent**: 25,000 × $1,000 = **$25,000,000**. If **reckless**: 25,000 × $5,000 = **$125,000,000**. The fix — one consent screen shipped before the first scan — costs essentially nothing.

Bottom line — the three that can kill you first

1	**Biometric consent (BIPA).** Ship the opt-in consent + retention/deletion before the first scan. Private suits + Illinois home base make this the #1 existential risk.
2	**Never let face/health data near an ad or analytics SDK.** This is the exact trap that fined GoodRx, BetterHelp, Premom, and Flo. No selling or third-party sharing.
3	**Stay cosmetic; never diagnose.** The moment the app diagnoses or treats disease it becomes an unapproved FDA medical device and an FTC false-claims target.

THE CHEAP INSURANCE

Every penalty on the previous page is avoided by the same modest upfront work: an opt-in consent flow, data minimization, no data sales/ad-SDKs, an 18+ gate, in-app delete, and a lawyer's review before launch. The compliance spec already specifies all of it. A few thousand dollars of legal review is the best-value spend the company will make.

This summary is illustrative and not legal advice. Penalty figures are statutory maximums or reported settlements and depend heavily on specific facts, intent, user counts, and jurisdiction. Confirm current amounts and your exposure with qualified counsel before launch. Sources: Illinois BIPA 740 ILCS 14; Texas CUBI; Washington MHMDA; FTC HBNR & §5 actions (GoodRx, BetterHelp, Premom, Flo); FTC COPPA actions (Epic, Cognosphere); FD&C; Act; state privacy AG settlements (Disney, Healthline); GDPR Art. 83. Current to mid-2026.